

INTERNATIONAL CYBERSECURITY AND
DIGITAL FORENSICS ACADEMY

Week 2 Assignment

Developing Security Policies and Procedures

ICDFA Security Policy Manual Development Project

Name	Adeshola Oluwole
Registration Number	C1126CGRCE17211
Course	GRC102 – Information Security Governance
Module	Module 2 – Developing Security Policies and Procedures
Week	Week 2: 12–18 September 2026
Opens	12 September 2026, 8:00 AM WAT
Due	18 September 2026, 11:59 PM WAT
Maximum Score	100 marks
Effective Course Contribution	8.75% of final course grade

Submission mode: File upload only (PDF or DOCX)

This assignment assesses policy development, governance alignment, implementation planning and effectiveness measurement.

1. Assignment Overview

ICDFA is strengthening its information security governance framework and requires a coherent, professional and implementable security policy manual. You have been appointed as an Information Security Policy Adviser and are responsible for translating governance objectives into clear organisational rules, responsibilities, procedures and measurable controls.

Your task is to develop a structured Security Policy Manual for ICDFA that demonstrates the relationship between policy, standard, procedure and guideline; defines practical security requirements; assigns ownership and accountability; aligns key requirements with recognised security frameworks; and establishes a lifecycle for approval, communication, exceptions, review and continuous improvement.

2. Learning Outcomes

- Distinguish and correctly apply the hierarchy of policy, standard, procedure and guideline.
- Develop clear, enforceable and business-aligned information security policies.
- Define ownership, accountability, enforcement and exception processes.
- Translate policy requirements into supporting procedures and operational expectations.
- Map key policy requirements to ISO/IEC 27001 control themes and NIST Cybersecurity Framework functions.
- Design policy communication, training, monitoring, review and continuous-improvement mechanisms.
- Develop meaningful metrics for measuring policy adoption, compliance and effectiveness.

3. Scenario

ICDFA has expanded its academic, cloud, laboratory and digital service environments. As its systems, users, partners and learning platforms grow, security requirements can no longer depend on informal practices or isolated technical decisions. Senior management have therefore authorised the creation of a formal Security Policy Manual that will provide consistent direction across personnel, systems, data, cloud services, laboratories and physical facilities.

As the assigned policy adviser, you must create a policy package that is practical enough to implement, clear enough for users to understand and structured enough to support governance oversight, auditability and continuous improvement.

4. Task 1 Establish the Policy Governance Framework

Before drafting individual policies, establish the policy architecture that will govern the entire manual.

1. Explain the difference between a Policy, Standard, Procedure and Guideline, including the purpose and authority of each.
2. Create a simple policy hierarchy showing how enterprise policy flows into topic-specific policies, standards, procedures and guidelines.
3. Define the policy lifecycle: drafting, consultation, approval, publication, communication, exception management, review, revision and retirement.
4. Identify the key stakeholders involved in the policy lifecycle and state their responsibilities.

Required Evidence Task 1

- Policy hierarchy diagram or table.
- Policy lifecycle workflow.
- Stakeholder responsibility table.
- Short explanatory narrative linking the framework to effective information security governance.

Policy Governance Framework

4.1 Difference between a Policy, Standard, Procedure and Guideline, including the purpose and authority of each.

S/No	Term	Purpose	Authority	Example - ICDFA
1	Policy	High-level documents that define the organization's position, requirements, and management intent. Policies answer "what" needs to be done or what the organisation requires and "why" it matters.	Approved by senior management/executive authority (e.g., ICDFA Board or CISO office)	All ICDFA information assets must be classified according to its sensitivity.
2	Standard	Mandatory requirements that support policies by providing specific details on what must be implemented. Standards define minimum requirements and acceptable behaviors.	Set by a designated authority (e.g., IT/Security function)	Passwords must be a minimum of 14 characters with MFA- enabled for all privileged accounts.
3	Procedure	Step-by-step instructions that detail exactly "how" to implement policies, standards, and guidelines. Procedures provide operational guidance for specific tasks.	Owned by operational teams	Steps for provisioning a new user account in the identity management system.
4	Guideline	Recommended approaches that are not mandatory but provide best practices and suggested methods for implementing policies and standards.	Advisory, not mandatory	Recommended practices for securing a personal device used for coursework.

Please note the following:

Policy addresses why and what

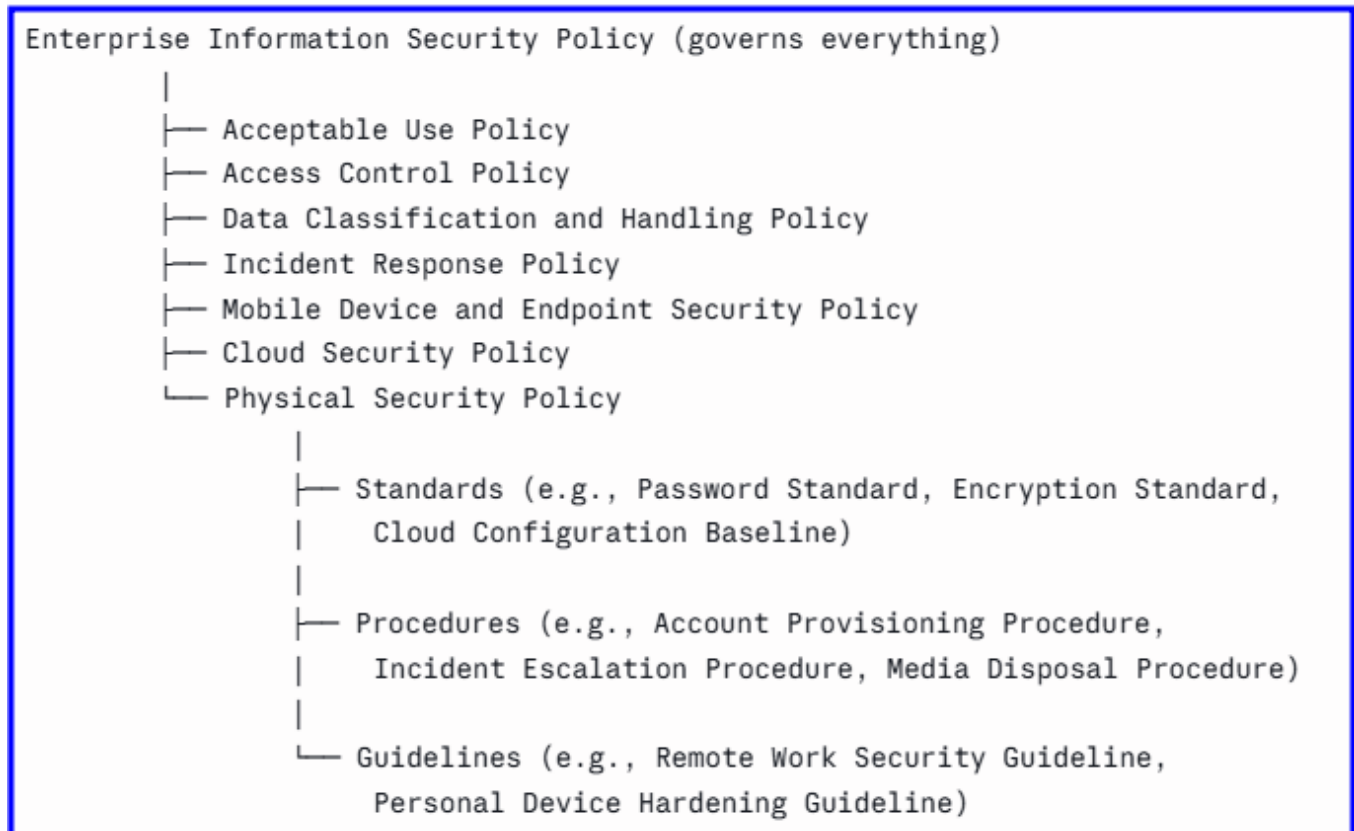
Standard addresses how much or how strict

Procedure addresses how exactly

Guideline addresses suggested

4.2 Policy Hierarchy

The policy hierarchy here shows from the top, a sole line of authority from the top which is the Enterprise Information Security Policy which goes down to the bottom. The Enterprise Policy is the root - it sets the authority and top-level rules. The 8 topic policies inherit from it and focus on specific areas. Standards and procedures just operationalize them, no board approval needed. That's what makes the manual one coherent system, not 8 separate docs.



4.3 Define the Policy Lifecycle

The Policy Lifecycle is the end-to-end process of creating, approving, implementing, monitoring, and retiring a policy. It ensures policies stay relevant, enforced, and regularly reviewed for effectiveness and compliance and the lifecycle process include:

- a. Drafting – the policy owner writes the draft with the template and the business and risk requirements.
- b. Consultation -the draft is then distributed across the relevant stakeholders for feedback.
- c. Approval – the document is signed off with a version control and date and approved by the approving authority which can be the Board or the CISO.
- d. Publication – the approved documented version is published through the intranet for/ portal
- e. Communication – communication is made through announcements, trainings and briefings.
- f. Exception management –
- g. Review – the policy is reviewed yearly or when there is an incident, audit or regulation
- h. Revision – the policy updates will have to go through consultation, approval and publication
- i. Retirement – the policy is withdrawn and archived when it is no longer needed.

4.4 Key Stakeholders involved in the Policy Lifecycle with their Responsibilities.

- a. The Senior Management / Board grants approvals, sponsors policy programs and ensures resources are provided.
- b. The CISO / Head of Information Security is responsible for the enterprise information security policy and approves topic policies
- c. The Policy Owner is responsible for the drafting and reviewing of assigned policies and responds to exception requests.
- d. GRC Team coordinates the standards of the draft, tracks the cycle of review and monitors the metrics
- e. Security Operations / IT are responsible for technical controls required by the policy
- f. HR helps to integrate policies into the onboarding and offboarding of staffs and students and also enforce the disciplinary enforcement processes.
- g. Legal / Data Protection Officer handles the reviewing of regulatory requirements and alignment
- h. Staff, Instructors and Students are to comply with policies, complete trainings and report incidents
- i. Internal Audit verifies compliance and policy effectiveness independently.

This structure strengthens governance by ensuring Traceability as every rule links back to an approved role., Accountability, here each policy has a clear owner, and Adaptability as standards can change without re-approving the policy. Without all these, security would rely on personal judgment, which is exactly the informal approach ICDFA is trying to move away from.

5. Task 2 Develop the ICDFA Security Policy Manual

Develop the following eight policy documents as the core of the ICDFA Security Policy Manual. Each policy must be written as an organisational policy, not as a general essay about the topic.

Required Policy	Purpose
1. Enterprise Information Security Policy	Defines ICDFA's overall security direction, governance principles, authority and organisational expectations.
2. Acceptable Use Policy (AUP)	Defines appropriate and prohibited use of ICDFA devices, networks, accounts, applications and digital resources.
3. Access Control Policy	Defines identity, authentication, authorisation, privileged access, account lifecycle and access review requirements.
4. Data Classification and Handling Policy	Defines data classification levels and handling, storage, sharing, retention and disposal expectations.
5. Incident Response Policy	Defines incident reporting, escalation, roles, evidence preservation, communication and post-incident review requirements.
6. Mobile Device and Endpoint Security Policy	Defines minimum security requirements for organisation-owned and authorised personal devices accessing ICDFA resources.
7. Cloud Security Policy	Defines requirements for approved cloud services, configuration, identity, logging, data protection, third-party risk and shared-responsibility governance.
8. Physical Security Policy	Defines controls for facilities, classrooms, laboratories, devices, media, visitor access and physical asset protection.

Mandatory Structure for Every Policy

- Document title, policy owner, approval authority, version, effective date and review date.
- Purpose and scope.
- Definitions, where required.
- Roles and responsibilities.
- Policy statements / mandatory requirements.
- Compliance and framework alignment.
- Exception process.
- Enforcement and consequences of non-compliance.
- Monitoring / verification requirements.
- Review and version-control requirements.
- Related standards, procedures, guidelines or references.

5.1 ICDFA Enterprise Information Security Policy

Field	Entry
Policy Title	Enterprise Information Security Policy
Policy Owner	Chief Information Security Officer (CISO)
Approval Authority	ICDFA Board / Senior Management
Version	1.0
Policy Status	Draft
Review Date	12 months from effective date, or following significant changes

1. Purpose

This Policy establishes the **International Cybersecurity and Digital Forensics Academy (ICDFA)** overall direction, principles and governance authority for information security. ICDFA's information security posture is inseparable from its academic mission as it holds sensitive teaching material, forensic evidence samples, malware specimens, penetration-testing infrastructure, student and staff personal data, research data, and partner/industry information, etc at a high level and threat-attractiveness level rather than a typical academic institution. This Policy exists to protect the confidentiality, integrity and availability of ICDFA's assets, to ensure ICDFA's own security practice is credible and defensible to the industry it trains people for, and to serve as the parent document from which all subordinate ICDFA policies, standards, procedures and guidelines derive their authority.

2. Scope

This Policy applies to all ICDFA staff, instructors, students, interns, volunteers, researchers, contractors, third-party service providers, and any individual or entity granted access to ICDFA's information systems, networks, devices, cloud services, teaching and research **laboratories** (including forensic labs and offensive-security/cyber-range environments), or physical facilities, regardless of location or ownership of the device used to access ICDFA resources.

3. Definitions

- **Information Asset:** Any data, system, application, device or service that stores, processes or transmits ICDFA information, including forensic evidence, malware samples, and lab/research data.
- **Information Security:** The preservation of confidentiality, integrity and availability of information assets.
- **Authorised Lab/Research Environment:** A segregated environment approved for controlled use of dual-use security or forensic tools and materials as part of ICDFA's teaching and research mission
- **Governance:** The framework of authority, accountability and oversight through which security direction is set and enforced.
- **Policy Suite:** The complete set of topic-specific policies, standards, procedures and guidelines issued under this Policy.

4. Roles and Responsibilities

- **ICDFA Board / Senior Management:** Approves the Policy; provides resourcing and visible sponsorship; holds the CISO accountable for the security programme, including the integrity of teaching/research lab environments.
- **CISO:** Owns the Policy; approves and oversees all subordinate topic-specific policies; reports security posture to senior management; chairs the policy governance process; approves the academy's Authorised Lab/Research Environment standards.
- **Policy Owners** (This is assigned per topic policy): Draft, maintain and review their respective policies under this Policy's authority.
- **Academic/Lab Leadership:** Ensures teaching and research activities involving sensitive tools or materials comply with this Policy and its subordinate policies.
- **GRC/Compliance Function:** Maintains the policy suite's internal consistency, tracks review cycles, and coordinates framework mapping.
- **IT/Security Operations:** Implements technical controls, including segregation of lab/research networks from production and administrative systems.
- **All Staff, Instructors, Students, Researchers and Third Parties:** Comply with this Policy and all subordinate policies applicable to their role; report suspected security weaknesses or incidents promptly.

5. Policy Statements / Mandatory Requirements

1. ICDFA's Information security shall be dully managed under a risk-based approach, inaccordance to the sensitivity and criticality of the asset concerned — recognising that ICDFA holds materials (malware samples, exploit code, forensic evidence, offensive-security tooling) that carry elevated risk if mismanaged.

2. All ICDFA information assets shall be protected regardless of format or location, including assets used for legitimate teaching and research purposes.
3. Teaching and research activity involving dual-use security or forensic tools shall only occur within an Authorised Lab/Research Environment, segregated from production and administrative systems, as further defined in the Acceptable Use Policy.
4. Every topic-specific security policy issued under this Enterprise Policy shall be approved by the CISO or the Board, in cases where the topic requires Board-level approval) before publication.
5. No individual may access, process or store ICDFA information — including forensic evidence or research data — in a manner inconsistent with this Policy or its subordinate policies.
6. Security responsibilities shall be explicitly assigned; no security function, including lab/research environment oversight, may remain without a named owner.
7. ICDFA shall maintain a documented policy hierarchy, lifecycle and exception process, applied consistently across the policy suite.
8. Security incidents, weaknesses or non-compliance — including any escape of malware samples or tooling from an authorised environment — shall be reported without undue delay through the appropriate channels as stipulated in the Incident Response Policy.
9. This Policy takes precedence over any conflicting local practice, departmental arrangement, or informal agreement.
10. ICDFA shall maintain security practices that are defensible and credible to industry and regulatory stakeholders, consistent with its position as a training provider for the cybersecurity and digital forensics profession.

6. Compliance and Framework Alignment

This Policy establishes the governance foundation aligned with the ISO/IEC 27001:2022 requirement for a documented information security management system (ISMS) and top-management-approved policy (ISO/IEC, 2022a), and with the NIST CSF 2.0 "Govern" function (NIST, 2024). With ICDFA's handling of forensic evidence and offensive-security materials, this Policy also anchors the academy's obligations under the Cybercrimes (Prohibition, Prevention, etc.) Act, 2015, as amended in 2024 (Federal Republic of Nigeria, 2015, 2024), and, where personal data is processed, the Nigeria Data Protection Act, 2023 (Federal Republic of Nigeria, 2023).

7. Exception Process

Any request to bypass this Policy or a subordinate policy — including a request to use dual-use tooling or materials outside an Authorised Lab/Research Environment — must be submitted in writing to the CISO, including business/academic justification, risk assessment, proposed compensating controls, and requested duration. Exceptions are time-limited, must be formally approved before the deviation begins, and are subject to periodic review. Unapproved deviations are treated as non-compliance.

8. Enforcement and Consequences of Non-Compliance

Failure to comply with this Policy will result in disciplinary action and including termination of employment or enrolment, termination of contracts with third parties, and referral to law enforcement where conduct is

unlawful. Enforcement is applied consistently regardless of role or seniority, including for instructors and researchers operating in lab environments.

9. Monitoring and Verification Requirements

The CISO shall report on the state of the policy suite (adoption, exceptions, review status, incidents linked to non-compliance, and lab/research environment integrity) to senior management at least quarterly. Compliance shall be verified through periodic internal audit and management review.

10. Review and Version Control

This Policy shall be reviewed at least annually, or earlier upon material organisational change, a significant incident, introduction of new lab/research capability, or a relevant legal/regulatory change. All revisions require re-approval by the Board and shall be version-controlled with a documented change history.

11. Related Documents and References

Acceptable Use Policy; Access Control Policy; Data Classification; Incident Response Policy; Mobile Device and Endpoint Security Policy; Cloud Security Policy; Physical Security Policy.

References: ISO/IEC, 2022a; NIST, 2024; Federal Republic of Nigeria, 2015; Federal Republic of Nigeria, 2023; Federal Republic of Nigeria, 2024.

5.2 ICDFA Acceptable Use Policy

Field	Entry
Policy Title	Acceptable Use Policy
Policy Owner	Head of IT Services
Approval Authority	Chief Information Security Officer (CISO)
Version	1.0
Policy Status	Draft
Review Date	12 months from effective date, or following significant changes

1. Purpose

This Policy defines appropriate and prohibited use of ICDFA-owned and ICDFA-authorised devices, networks, accounts, applications, cloud services, and digital resources by staff, instructors, students, interns, volunteers, contractors and third parties. It exists to protect ICDFA's academic and operational environment while recognising that ICDFA's teaching and research mission requires controlled use of technical tools such as penetration testing tools, forensic imaging software, malware samples, etc that would be inappropriate at a typical institution.

2. Scope

This Policy applies to all users of ICDFA IT resources, including personally owned devices connecting to ICDFA networks or accounts, and covers use both on ICDFA premises and remotely.

3. Definitions

- **ICDFA IT Resources:** Networks, endpoints, servers, cloud services, accounts, software and data owned, licensed, or authorised by ICDFA.
- **Authorised Lab Environment:** A segregated, instructor- or lab-supervisor-approved environment (physical or virtual) designated for security/forensics training activities that would otherwise be prohibited on production systems.
- **Dual-Use Tool:** Software with legitimate security/forensic training value that can also cause harm if misused outside an authorised environment (e.g., exploitation frameworks, packet sniffers, password-cracking tools).

4. Roles and Responsibilities

- **Head of IT Services:** Owns this Policy; maintains the list of approved software and authorised lab environments.
- **Lab Supervisors/Instructors:** Approve and supervise use of dual-use tools within authorised lab environments; ensure containment (network segregation, no bridging to production systems).
- **All Users:** Comply with this Policy; use ICDFA resources only for their intended academic, research or operational purpose.
- **IT Security Operations:** Monitors for unauthorised use of dual-use tools outside approved lab environments; investigates flagged activity.

5. Policy Statements / Mandatory Requirements

1. ICDFA IT resources must be used ethically primarily for academic, research, administrative or operational purposes consistent with ICDFA's mission.
2. Reasonable, incidental personal use is permitted provided it does not interfere with duties/studies, consume disproportionate resources, or violate any other ICDFA policy or law.
3. Dual-use security and forensic tools (e.g., Metasploit, Wireshark, Kali Linux toolsets, hash-cracking utilities, malware samples) may only be used within an Authorised Lab Environment, under instructor/lab-supervisor approval, on systems and networks explicitly designated for that purpose. Use of such tools against any ICDFA production system, third-party system, or network without explicit written authorisation is strictly prohibited and may constitute a criminal offence under the Cybercrimes (Prohibition, Prevention, etc.) Act, 2015, as amended in 2024 (Federal Republic of Nigeria, 2015, 2024).
4. Users must not attempt to access accounts, data, or systems they are not explicitly authorised to access, including "testing" access controls outside an authorised assessment.
5. Users must not install unauthorised software on ICDFA-owned devices, or disable security controls (antivirus, endpoint monitoring, patching agents) without IT Services approval.

6. ICDFA IT resources must not be used to violate the law, harass others, infringe intellectual property, or bring ICDFA into disrepute.
7. Credentials (passwords, tokens, access cards) are personal and must not be shared.
8. Users must report any suspected misuse, security weakness, or unauthorised access to IT Services or via the Incident Response Policy's reporting channel.
9. ICDFA reserves the right to monitor use of its IT resources in accordance with applicable law and this Policy, primarily for security and operational purposes.

6. Compliance and Framework Alignment

This Policy supports ISO/IEC 27002:2022 controls on acceptable use of information and associated assets, and on the use of privileged/technical tools (ISO/IEC, 2022b). It aligns with the NIST CSF 2.0 "Protect" function, specifically identity management and platform security practices (NIST, 2024). The dual-use tool provisions aligns with the obligations under the Cybercrimes (Prohibition, Prevention, etc.) Act, 2015, and its 2024 Amendment, which criminalise unauthorised access to computer systems (Federal Republic of Nigeria, 2015, 2024).

7. Exception Process

Requests to use a dual-use tool outside a pre-approved lab environment (e.g., for a specific research project) must be submitted in writing to the Head of IT Services with a defined scope, isolation plan, and time limit, and require CISO sign-off before use begins.

8. Enforcement and Consequences of Non-Compliance

Violations may result in suspension of IT access, disciplinary or academic proceedings, and — where conduct is unlawful (e.g., unauthorised access outside an approved lab) — referral to law enforcement under applicable Nigerian legislation.

9. Monitoring/Verification Requirements

IT Security Operations shall monitor network traffic and endpoint activity for indicators of dual-use tools running outside registered lab network segments, and shall report findings to the Head of IT Services monthly.

10. Review and Version-Control Requirements

Reviewed annually or upon introduction of new lab tooling, a significant incident involving misuse, or relevant legal change. Revisions follow the lifecycle defined in the Enterprise Information Security Policy.

11. Related Documents and References

Enterprise Information Security Policy; Access Control Policy; Incident Response Policy; Mobile Device and Endpoint Security Policy.

References: ISO/IEC, 2022b; NIST, 2024; Federal Republic of Nigeria, 2015; Federal Republic of Nigeria, 2024.

5.3 ICDFA Access Control Policy

Field	Entry
Policy Title	Access Control Policy
Policy Owner	Head of IT Services
Approval Authority	Chief Information Security Officer
Version	1.0
Policy Status	Draft
Review Date	12 months from effective date, or following significant changes

1. Purpose

This Policy defines identity, authentication, authorisation, privileged access, account lifecycle, and access review requirements across ICDFA's systems, networks, cloud services and laboratory environments. Given ICDFA's role as a cybersecurity and digital forensics academy, access control failures carry elevated consequences such as unauthorised access to forensic evidence which can break chain of custody, and unauthorised access to lab/cyber-range environments which can expose live exploit tooling or malware samples beyond their intended scope. This Policy exists to ensure that access to ICDFA information assets is granted only to authorised individuals, at the minimum level necessary, and is revoked promptly when it is no longer required.

2. Scope

This Policy applies to all accounts, systems, applications, cloud services, network segments, and physical/virtual laboratory environments at ICDFA, and to all staff, instructors, students, researchers, contractors and third parties who hold any form of access to them.

3. Definitions

- **Identity:** The unique digital representation of a person or system used to authenticate and authorise access.
- **Authentication:** The process of verifying a claimed identity (e.g., password, multi-factor authentication).
- **Authorisation:** The process of granting a verified identity specific, defined permissions.
- **Privileged Access:** Access rights that exceed standard user permissions (e.g., system administration, forensic evidence repository access, lab/cyber-range administration).
- **Least Privilege:** The principle that access is limited to the minimum necessary to perform an authorised function.
- **Chain of Custody Access:** Access to forensic evidence or case data that must be logged and attributable to a specific individual to preserve evidentiary integrity.

4. Roles and Responsibilities

- **Head of IT Services:** Owns this Policy; administers the identity and access management (IAM) system; ensures account lifecycle processes are followed.
- **CISO:** Approves privileged access requests for high-sensitivity systems (forensic evidence repositories, cyber-range administration); reviews access control effectiveness.
- **System/Data Owners:** Approve access requests to their respective systems or data sets based on role and need.
- **Lab Supervisors:** Approve and log access to authorised lab/research environments and any evidence or tooling held within them.
- **All Users:** Safeguard their own credentials; use only the access explicitly granted to them; report suspected unauthorised access immediately.
- **Internal Audit/GRC:** Periodically verifies access reviews and privileged access appropriateness.

5. Policy Statements / Mandatory Requirements

1. Access to all ICDFA systems and data shall be granted on the basis of **least privilege** and documented business/academic need.
2. All user accounts shall be uniquely identifiable; shared or generic accounts are prohibited except where formally approved with compensating controls (e.g., a supervised shared lab account with individual sign-in logging).
3. **Multi-factor authentication (MFA)** is mandatory for all remote access, all privileged accounts, and all access to forensic evidence repositories and cyber-range administration interfaces.
4. Access to **forensic evidence or case data** must be logged with full chain-of-custody attribution (who, what, when) and must never be granted on a shared or generic account.
5. Access to **Authorised Lab/Research Environments** containing dual-use tools or malware samples requires explicit approval from a Lab Supervisor, is time-bound to the relevant course/project, and is automatically reviewed at course/project completion.
6. **Privileged access** (system administration, security tooling administration, forensic repository access) must be formally approved, individually justified, and reviewed at least every six months.
7. User accounts must be provisioned only after approval by the relevant system/data owner, and deprovisioned **immediately** upon termination of employment, contract, or enrolment, or role change that removes the need for access.
8. Access rights must be reviewed at least **quarterly** for privileged accounts and **annually** for standard accounts; discrepancies must be corrected and logged.
9. Password and authentication requirements shall meet the minimum standard defined in the supporting Password/Authentication Standard (a subordinate standard to this Policy).

10. Failed authentication attempts, privileged access use, and forensic repository access shall be logged and retained per the Data Classification and Handling Policy's retention requirements.

6. Compliance and Framework Alignment

This Policy aligns with **ISO/IEC 27001:2022 Annex A** control themes on access control, identity management, and privileged access rights (ISO/IEC, 2022a), and **ISO/IEC 27002:2022** implementation guidance on the same (ISO/IEC, 2022b). It supports the **NIST CSF 2.0 "Protect" function**, specifically identity management, authentication and access control (PR.AA) (NIST, 2024). Chain-of-custody access logging supports evidentiary admissibility consistent with Nigerian criminal procedure and the **Cybercrimes (Prohibition, Prevention, etc.) Act, 2015/2024**, which governs the handling of electronic evidence (Federal Republic of Nigeria, 2015, 2024). Where access controls protect personal data, this Policy also supports obligations under the **Nigeria Data Protection Act, 2023** (Federal Republic of Nigeria, 2023).

7. Exception Process

Requests for exceptions (e.g., a shared account for a specific lab exercise, or extended privileged access beyond the standard review cycle) must be submitted in writing to the Head of IT Services with justification and compensating controls, and approved by the CISO before implementation. All exceptions are logged in the central exceptions register and reviewed at expiry.

8. Enforcement and Consequences of Non-Compliance

Unauthorised access, credential sharing, or failure to deprovision access on request may result in disciplinary or academic action, suspension of access, and — where forensic evidence integrity is compromised or unauthorised access to systems occurs — referral to law enforcement under applicable law.

9. Monitoring/Verification Requirements

IT Services shall generate quarterly privileged-access review reports and forensic-repository access logs for CISO sign-off. Automated alerts shall flag access attempts outside approved lab time windows or by deprovisioned accounts.

10. Review and Version-Control Requirements

Reviewed annually, or upon a significant access-related incident, introduction of a new high-sensitivity system (e.g., a new forensic tool repository), or relevant regulatory change. Revisions follow the lifecycle defined in the Enterprise Information Security Policy.

11. Related Documents and References

Enterprise Information Security Policy; Acceptable Use Policy; Data Classification and Handling Policy; Incident Response Policy; Password/Authentication Standard (subordinate).

References: ISO/IEC, 2022a; ISO/IEC, 2022b; NIST, 2024; Federal Republic of Nigeria, 2015; Federal Republic of Nigeria, 2023; Federal Republic of Nigeria, 2024.

5.4 ICDFA Data Classification Policy

Field	Entry
Policy Title	Data Classification and Handling Policy
Policy Owner	Head of GRC / Data Protection Officer (DPO)
Approval Authority	Chief Information Security Officer (CISO)
Version	1.0
Policy Status	Draft
Review Date	12 months from effective date, or following significant changes

1. Purpose

This Policy defines the classification levels for ICDFA information assets and the mandatory requirements for handling, storage, sharing, retention and disposal of information across its lifecycle — from creation or receipt to final destruction. Given ICDFA's mission, its data holdings range from routine administrative records to highly sensitive material — student/staff personal data, unreleased exam content, live and simulated forensic case evidence, and malware samples — each carrying different legal, evidentiary and reputational consequences if mishandled. This Policy ensures information is classified consistently and handled in a manner proportionate to its sensitivity at every stage of that lifecycle.

2. Scope

This Policy applies to all information created, received, stored, processed, transmitted or disposed of by ICDFA, in any format (digital, physical, verbal), and to all staff, instructors, students, researchers, contractors and third parties who handle ICDFA information, regardless of the system, device or location involved.

3. Definitions

- **Data Classification:** The assignment of a sensitivity level to information to determine the controls required to protect it.
- **Data Handling:** The set of practices governing how classified information is stored, accessed, shared, transmitted, retained and disposed of.
- **Data Owner:** The individual or function accountable for a given category of information, its classification, and approval of handling exceptions.
- **Data Custodian:** The individual or function responsible for implementing handling controls on behalf of the Data Owner (e.g., IT Services, Lab Supervisors).

- **Forensic Evidence:** Digital or physical material collected, preserved or analysed as part of a forensic case, real or simulated for teaching purposes.
- **Secure Disposal:** Destruction of data or media such that the information cannot be reconstructed or recovered.

4. Roles and Responsibilities

- **Head of GRC/DPO:** Owns this Policy; maintains the classification scheme and handling standards; advises on classification of ambiguous or novel data types.
- **Data Owners** (e.g., Registrar for student records, Lab Supervisors for case evidence, HR for staff records): Classify data within their domain; approve sharing, retention exceptions and disposal sign-off.
- **Data Custodians** (IT Services, Lab Supervisors, Facilities for physical records): Implement the technical, procedural and physical controls required for each classification level, including storage, transmission safeguards and disposal execution.
- **All Users:** Handle data according to its classification; classify newly created data at the point of creation where responsible for doing so; never bypass handling controls for convenience.

5. Policy Statements / Mandatory Requirements

5.1 Classification Levels

5.1.1 **Public** -This is approved for external release that is unrestricted such as published research, course brochures, etc.

5.1.2 **Internal** – This is used within ICDFA and are not meant for external release such as internal memos.

5.1.3 **Confidential** – These are sensitive data and an unauthorized disclosure will be harmful such as staff and student data, unpublished examination materials.

5.1.4 **Restricted** – This has the highest level of sensitive data and an unauthorized disclosure will lead to severe harm and reputational damage.

5.2 Classification Requirements

2. Every information asset must be classified at the point of creation or receipt by the responsible Data Owner; where classification is unclear, the Head of GRC/DPO shall be consulted.

3. Classification labels must be applied to documents, datasets, and repositories (e.g., via metadata, folder structure, header/footer marking, or physical stamping) so custodians and users can identify the required controls at a glance.

4. Classification must be reassessed if the sensitivity of the data changes (e.g., a simulated exercise dataset is later used in a real investigation).

5.3 Storage Requirements

5. **Confidential** and **Restricted** data must be encrypted at rest, using an encryption standard approved by IT Services.

6. **Restricted** data (forensic evidence, malware samples, exploit code) must be stored in segregated,

access-logged repositories, physically or logically separate from general Internal/Confidential storage, consistent with the Access Control Policy's chain-of-custody requirements.

7. Physical records classified Confidential or Restricted must be stored in locked, access-controlled storage consistent with the Physical Security Policy.

5.4 Transmission and Sharing Requirements

8. **Confidential** and **Restricted** data must be encrypted in transit whenever transmitted over any network, internal or external.

9. Sharing of **Confidential** or **Restricted** data outside ICDFA requires Data Owner approval and, where personal data is involved, must meet the lawful basis and cross-border transfer requirements of the Nigeria Data Protection Act, 2023.

10. Restricted data must never be shared via unmanaged personal accounts, consumer file-sharing services, or removable media, except where the Data Owner has approved a specific, controlled exception.

5.5 Retention Requirements

11. Retention periods shall be defined per data category by the relevant Data Owner and shall not exceed what is necessary for the academic, legal, or evidentiary purpose.

12. Forensic case evidence used for teaching shall have retention terms defined at the start of the course/lab exercise and documented by the Lab Supervisor.

13. Personal data retention shall follow data-minimisation and storage-limitation principles under the Nigeria Data Protection Act, 2023, and shall not be kept "just in case" beyond its defined purpose.

5.6 Disposal Requirements

14. Disposal of **Confidential** and **Restricted** data (digital or physical) must use secure destruction methods appropriate to the medium (e.g., cryptographic erasure, certified degaussing/shredding for physical media) and must be logged with date, method, and authorising Data Owner.

15. Malware samples and exploit code classified Restricted must never be transferred outside an Authorised Lab/Research Environment without CISO approval and documented containment measures, and must be securely destroyed at the end of their approved use unless retained under an active exception.

6. Compliance and Framework Alignment

This Policy aligns with **ISO/IEC 27001:2022 Annex A** control themes on classification of information and handling of assets, including media handling and disposal (ISO/IEC, 2022a), and **ISO/IEC 27002:2022** implementation guidance on information labelling, storage, transmission and secure disposal (ISO/IEC, 2022b). It supports the **NIST CSF 2.0 "Protect" function**, specifically data security (PR.DS), covering data-at-rest, data-in-transit and data-disposal practices (NIST, 2024). Handling of personal data under the Confidential category is governed by the **Nigeria Data Protection Act, 2023**, including its data minimisation, storage-limitation and cross-border transfer provisions (Federal Republic of Nigeria, 2023). Handling of Restricted forensic evidence and malware samples supports evidentiary integrity obligations under the **Cybercrimes (Prohibition, Prevention, etc.) Act, 2015/2024** (Federal Republic of Nigeria, 2015, 2024).

7. Exception Process

Requests to deviate from standard handling requirements (e.g., temporary storage of Restricted data outside the designated repository, an extended retention period, or an alternative sharing mechanism) must be submitted in writing to the relevant Data Owner and approved by the CISO, with compensating controls and an expiry date documented in the exceptions register.

8. Enforcement and Consequences of Non-Compliance

Mishandling of Confidential or Restricted data — including unclassified storage of forensic evidence, unauthorised sharing, improper disposal, or unauthorised transfer of malware samples — may result in disciplinary or academic action and, where unlawful, referral to law enforcement.

9. Monitoring/Verification Requirements

Data Owners shall conduct an annual classification and handling audit of their domain's data holdings, covering storage, sharing logs, retention compliance and disposal records. IT Services shall report encryption and access-control compliance for Confidential/Restricted repositories to the CISO quarterly.

10. Review and Version-Control Requirements

Reviewed annually, or upon introduction of a new data category (e.g., a new forensic tool generating a new evidence type), a classification or handling-related incident, or relevant legal change.

11. Related Documents and References

Enterprise Information Security Policy; Access Control Policy; Acceptable Use Policy; Incident Response Policy; Physical Security Policy; Cloud Security Policy.

References: ISO/IEC, 2022a; ISO/IEC, 2022b; NIST, 2024; Federal Republic of Nigeria, 2015; Federal Republic of Nigeria, 2023; Federal Republic of Nigeria, 2024.

5.5 ICDFA Incident Response Policy

Field	Entry
Policy Title	Incident Response Policy
Policy Owner	Head of Security Operations
Approval Authority	Chief Information Security Officer (CISO)
Version	1.0
Policy Status	Draft
Review Date	12 months from effective date, or following significant changes

1. Purpose

This Policy defines how ICDFA identifies, reports, escalates, responds to, and learns from information security incidents. Because ICDFA trains incident responders and forensic investigators, its own incident handling must be defensible and exemplary — a poorly handled incident at ICDFA would undermine institutional credibility with the profession it serves, in addition to any operational or legal harm.

2. Scope

Applies to all suspected or confirmed security incidents affecting ICDFA's information assets, networks, cloud services, laboratories (including cyber-range/forensic environments), and physical facilities, and to all staff, instructors, students, researchers, contractors and third parties.

3. Definitions

- **Security Incident:** An event that compromises, or threatens to compromise, the confidentiality, integrity or availability of an ICDFA information asset.
- **Escape:** An incident where a lab-contained tool, malware sample, or exploit intended for teaching purposes leaves its Authorised Lab/Research Environment.
- **Chain of Custody:** The documented, unbroken record of evidence handling required to preserve its integrity for potential legal or disciplinary use.

4. Roles and Responsibilities

- **Head of Security Operations:** Owns this Policy; leads incident triage and technical response; maintains the incident log.
- **CISO:** Approves escalation to senior management/regulators; final decision-maker on major incidents.
- **Incident Response Team (IRT):** Cross-functional (IT, GRC, Legal/DPO, Communications) group activated for significant incidents.
- **Lab Supervisors:** First point of report for any suspected tool/malware escape from a lab environment; support containment.
- **All Users:** Report suspected incidents immediately via the defined reporting channel; do not attempt independent remediation of suspected compromises.
- **DPO:** Assesses personal-data-breach notification obligations under the NDPA.

5. Policy Statements / Mandatory Requirements

1. All suspected security incidents must be reported immediately to the Security Operations reporting channel (e.g., a dedicated email/hotline), regardless of the reporter's certainty.
2. Incidents shall be triaged and classified by severity (e.g., Low/Medium/High/Critical) within a defined timeframe (e.g., 1 hour for Critical) from report.
3. A **malware/tool escape from an Authorised Lab/Research Environment** is automatically classified at minimum High severity and triggers immediate network containment procedures.
4. Evidence relating to an incident must be preserved following documented chain-of-custody procedures from the moment of detection.
5. The IRT shall be activated for all High/Critical incidents, coordinating technical containment, business/academic continuity, communications, and legal/regulatory assessment.
6. Where an incident involves personal data, the DPO shall assess notification obligations under the Nigeria Data Protection Act, 2023, including timelines for notifying the NDPC and affected data subjects where required.

7. A post-incident review shall be conducted for all Medium severity and above incidents, producing lessons learned and corrective actions with owners and deadlines.
8. Incident status, root cause, and remediation must be documented in a central incident register, retained per the Data Classification and Handling Policy.
9. Communications about an incident (internal or external, including media) must be coordinated through the IRT; individuals must not speculate publicly about an ongoing incident.

6. Compliance and Framework Alignment

Aligned with **ISO/IEC 27001:2022 Annex A** incident management controls and **ISO/IEC 27002:2022** guidance on incident response planning, evidence collection and lessons learned (ISO/IEC, 2022a, 2022b). Supports the **NIST CSF 2.0 "Respond" and "Recover" functions** (NIST, 2024). Personal data breach handling aligns with notification obligations under the **Nigeria Data Protection Act, 2023** (Federal Republic of Nigeria, 2023). Evidence handling during incidents supports admissibility requirements consistent with the **Cybercrimes Act, 2015/2024** (Federal Republic of Nigeria, 2015, 2024).

7. Exception Process

Any deviation from standard containment procedure (e.g., delaying isolation of a system for evidentiary reasons) requires real-time CISO approval, documented in the incident record.

8. Enforcement and Consequences of Non-Compliance

Failure to report a known incident, or unauthorised independent remediation that destroys evidence, may result in disciplinary or academic action.

9. Monitoring/Verification Requirements

Security Operations shall report incident volume, severity trends, and time-to-containment metrics to the CISO monthly. Incident response procedures shall be tested via tabletop exercises at least annually.

10. Review and Version-Control Requirements

Reviewed annually or after any Critical incident, regulatory change, or significant post-incident review finding.

11. Related Documents and References

Enterprise Information Security Policy; Access Control Policy; Data Classification and Handling Policy; Acceptable Use Policy.

References: ISO/IEC, 2022a; ISO/IEC, 2022b; NIST, 2024; Federal Republic of Nigeria, 2015; Federal Republic of Nigeria, 2023; Federal Republic of Nigeria, 2024.

5.6 ICDFA Mobile Device Security Policy

Field	Entry
Policy Title	Mobile Device Security Policy
Policy Owner	Head of IT Services
Approval Authority	Chief Information Security Officer (CISO)
Version	1.0
Policy Status	Draft
Review Date	12 months from effective date, or following significant changes

1. Purpose

This Policy defines minimum security requirements for organisation-owned and authorised personal ("BYOD") devices accessing ICDFA resources, including laptops used for forensic analysis or penetration-testing coursework, which carry elevated risk given the tools and data they may hold.

2. Scope

Applies to all laptops, desktops, smartphones, tablets, and removable media (organisation-owned or personally owned) that access, store, or process ICDFA information, including devices used in labs.

3. Definitions

- **Endpoint:** Any device that connects to ICDFA networks or holds ICDFA data.
- **BYOD:** Bring-your-own-device — a personally owned endpoint authorised for ICDFA use.
- **Forensic Workstation:** An endpoint specifically configured and hardened for forensic analysis, often holding case evidence or specialised tooling.

4. Roles and Responsibilities

- **Head of IT Services:** Owns this Policy; maintains endpoint security baselines and mobile device management (MDM) enrolment.
- **Lab Supervisors:** Ensure forensic workstations and lab endpoints meet hardening requirements before use.
- **All Users:** Keep devices updated, report loss/theft immediately, and comply with enrolment requirements for any device accessing ICDFA resources.

5. Policy Statements / Mandatory Requirements

1. All endpoints accessing ICDFA resources must have up-to-date antivirus/endpoint detection, full-disk encryption, and a locking passcode/biometric enabled.

2. **Forensic workstations** must be hardened per a documented baseline, isolated from general internet access where feasible during evidence analysis, and never used for unrelated personal activity.
3. BYOD devices must be enrolled in ICDFA's MDM (or equivalent) solution before accessing Confidential or Restricted data; devices that cannot meet minimum security baselines will be denied access.
4. Lost or stolen devices holding ICDFA data must be reported immediately to IT Services to enable remote wipe where technically possible.
5. Operating systems and applications on ICDFA-managed endpoints must be kept current with security patches per IT Services' patching schedule.
6. Removable media (USB drives, external disks) used to transport Confidential or Restricted data (including evidence) must be encrypted and logged.
7. Endpoints used within an Authorised Lab/Research Environment must not bridge network connectivity between the lab segment and the general ICDFA network.
8. Personal use of forensic workstations or lab endpoints for non-academic purposes is prohibited.

6. Compliance and Framework Alignment

Aligned with **ISO/IEC 27001:2022 Annex A** controls on endpoint/mobile device security (ISO/IEC, 2022a), **ISO/IEC 27002:2022** guidance on teleworking and mobile devices (ISO/IEC, 2022b), and the **NIST CSF 2.0 "Protect" function** (platform security) (NIST, 2024). Evidence-handling requirements on forensic workstations support the **Cybercrimes Act, 2015/2024** (Federal Republic of Nigeria, 2015, 2024).

7. Exception Process

Requests for a non-standard device configuration (e.g., a specialised forensic tool requiring reduced hardening) must be approved by the CISO with documented compensating controls.

8. Enforcement and Consequences of Non-Compliance

Non-compliant devices may be denied network access; policy violations may result in disciplinary or academic action.

9. Monitoring/Verification Requirements

IT Services shall run quarterly compliance scans of managed endpoints and report exceptions to the CISO.

10. Review and Version-Control Requirements

Reviewed annually or upon a device-related incident or new endpoint category introduction (e.g., new forensic hardware).

11. Related Documents and References

Enterprise Information Security Policy; Access Control Policy; Data Classification and Handling Policy; Acceptable Use Policy.

References: ISO/IEC, 2022a; ISO/IEC, 2022b; NIST, 2024; Federal Republic of Nigeria, 2015; Federal Republic of Nigeria, 2024.

5.7 ICDFA Cloud Security Policy

Field	Entry
Policy Title	Cloud Security Policy
Policy Owner	Head of IT Services
Approval Authority	Chief Information Security Officer (CISO)
Version	1.0
Policy Status	Draft
Review Date	12 months from effective date, or following significant changes

1. Purpose

This Policy defines requirements for approved cloud services used by ICDFA, covering configuration, identity, logging, data protection, third-party risk, and the shared-responsibility model — including cloud-hosted cyber-range and virtual lab platforms used for teaching.

2. Scope

Applies to all cloud services (IaaS, PaaS, SaaS) used to store, process or provide access to ICDFA information or teaching environments, including vendor-hosted cyber-range platforms.

3. Definitions

- **Shared Responsibility Model:** The division of security obligations between a cloud provider and ICDFA as customer.
- **Cyber-Range Platform:** A cloud-hosted virtual environment used for hands-on security/forensics training.
- **Shadow IT:** Cloud services adopted without IT Services approval or oversight.

4. Roles and Responsibilities

- **Head of IT Services:** Owns this Policy; maintains the approved cloud services register; vets new cloud services before adoption.
- **CISO:** Approves cloud services handling Confidential/Restricted data or hosting cyber-range platforms.
- **Data Owners:** Confirm that a cloud service meets classification-appropriate protections before their data is stored there.
- **All Users:** Use only approved cloud services for ICDFA data and coursework; do not adopt unapproved ("shadow IT") services for institutional data.

5. Policy Statements / Mandatory Requirements

1. Only cloud services on the approved register may be used to store or process ICDFA data or host teaching environments.
2. Before approval, IT Services shall assess each cloud service's shared-responsibility model, data residency, security certifications (e.g., ISO/IEC 27001 certification of the provider), and incident notification terms.
3. MFA and least-privilege access (per the Access Control Policy) apply equally to cloud service accounts, including cyber-range platform administration.
4. Logging must be enabled on all cloud services handling Confidential/Restricted data, with logs retained per the Data Classification and Handling Policy and reviewed for anomalies.
5. Data stored in cloud services must be encrypted at rest and in transit, consistent with the Data Classification and Handling Policy.
6. Cyber-range or lab cloud environments must be logically segregated per class/cohort, with no cross-tenant access to another group's exercises or data.
7. Cloud service contracts must include data protection and security terms consistent with ICDFA's obligations under the Nigeria Data Protection Act, 2023, including any cross-border data transfer safeguards.
8. Use of free-tier, unvetted or personal cloud accounts for institutional data (including student project data) is prohibited.
9. IT Services shall maintain an offboarding process to revoke access and confirm data deletion when a cloud service or vendor relationship ends.

6. Compliance and Framework Alignment

Aligned with **ISO/IEC 27001:2022 Annex A** controls on cloud services and supplier relationships (ISO/IEC, 2022a), **ISO/IEC 27002:2022** cloud security guidance (ISO/IEC, 2022b), and the **NIST CSF 2.0 "Govern" and "Protect" functions**, including supply chain risk management (NIST, 2024). Cross-border data handling aligns with the **Nigeria Data Protection Act, 2023** (Federal Republic of Nigeria, 2023); where EU-affiliated data or partners are involved, **GDPR** provisions may also apply (European Parliament and Council of the European Union, 2016).

7. Exception Process

Use of a non-approved cloud service for a specific project must be requested in writing to IT Services and approved by the CISO with a documented risk assessment.

8. Enforcement and Consequences of Non-Compliance

Use of unapproved cloud services for institutional data may result in disciplinary or academic action and mandatory data migration/deletion.

9. Monitoring/Verification Requirements

IT Services shall review the approved cloud services register and associated logging/configuration compliance quarterly.

10. Review and Version-Control Requirements

Reviewed annually or upon onboarding a new cloud service category, a cloud-related incident, or vendor contract renewal.

11. Related Documents and References

Enterprise Information Security Policy; Access Control Policy; Data Classification and Handling Policy; Incident Response Policy.

References: ISO/IEC, 2022a; ISO/IEC, 2022b; NIST, 2024; Federal Republic of Nigeria, 2023; European Parliament and Council of the European Union, 2016.

5.8 ICDFA Physical Security Policy

Field	Entry
Policy Title	Physical Security Policy
Policy Owner	Head of IT Services / Head of Facilities
Approval Authority	Chief Information Security Officer (CISO)
Version	1.0
Policy Status	Draft
Review Date	12 months from effective date, or following significant changes

1. Purpose

This Policy defines physical security controls for ICDFA facilities, classrooms, laboratories, devices, media and visitor access — with particular attention to labs holding forensic evidence, malware samples, and cyber-range infrastructure, which require stricter physical controls than general classrooms.

2. Scope

Applies to all ICDFA premises, including classrooms, offices, server/network rooms, forensic and cyber-range labs, and to all staff, instructors, students, contractors and visitors.

3. Definitions

- **Restricted Area:** A physical space (e.g., forensic lab, server room) requiring elevated access control beyond general facility access.
- **Evidence Locker:** A secured physical storage facility for physical forensic evidence and media.

4. Roles and Responsibilities

- **Head of Facilities:** Owns general physical security controls (building access, visitor management, CCTV).

- **Head of IT Services:** Owns physical security of server/network rooms and general IT hardware.
- **Lab Supervisors:** Own physical access control to forensic/cyber-range labs and the evidence locker.
- **All Users:** Do not prop open secured doors, share access cards/codes, or admit unauthorised visitors to restricted areas.

5. Policy Statements / Mandatory Requirements

1. General ICDFA premises require access card or equivalent control at entry points, with visitor sign-in and escort requirements.
2. **Forensic labs, cyber-range rooms, server rooms, and the evidence locker** are designated **Restricted Areas** requiring individually logged access (card/biometric) beyond general facility access; access lists shall be reviewed quarterly.
3. CCTV coverage shall be maintained at entry points to Restricted Areas, with footage retained per the Data Classification and Handling Policy's retention schedule.
4. Physical evidence must be stored in the Evidence Locker with individually logged access, maintaining chain of custody consistent with the Access Control Policy and Incident Response Policy.
5. Visitors to Restricted Areas must be pre-approved, signed in, and escorted at all times by an authorised staff member or Lab Supervisor.
6. Devices and media containing Confidential or Restricted data must not be left unattended in unsecured areas; workstations must be locked when unattended.
7. Environmental controls (fire suppression, power backup) shall be maintained for server rooms and cyber-range infrastructure to support availability requirements.
8. Physical access rights must be revoked immediately upon termination of employment, contract, or enrolment.

6. Compliance and Framework Alignment

Aligned with **ISO/IEC 27001:2022 Annex A** physical and environmental security controls (ISO/IEC, 2022a), and **ISO/IEC 27002:2022** guidance on secure areas and equipment security (ISO/IEC, 2022b). Supports the **NIST CSF 2.0 "Protect" function** (PR.AA covering physical access) (NIST, 2024). Evidence locker controls support chain-of-custody requirements relevant to the **Cybercrimes Act, 2015/2024** (Federal Republic of Nigeria, 2015, 2024).

7. Exception Process

Temporary access to a Restricted Area outside standard authorisation (e.g., after-hours lab access for a project deadline) must be approved in advance by the relevant Lab Supervisor or Head of Facilities, logged, and time-limited.

8. Enforcement and Consequences of Non-Compliance

Unauthorised access to Restricted Areas, credential sharing, or evidence locker mishandling may result in disciplinary or academic action and, where evidence integrity is compromised, referral to law enforcement.

9. Monitoring/Verification Requirements

Facilities/IT Services shall conduct quarterly access log reviews for Restricted Areas and the evidence locker, reporting anomalies to the CISO.

10. Review and Version-Control Requirements

Reviewed annually or upon a physical security incident, facility change, or introduction of a new Restricted Area.

11. Related Documents and References

Enterprise Information Security Policy; Access Control Policy; Data Classification and Handling Policy; Incident Response Policy.

References: ISO/IEC, 2022a; ISO/IEC, 2022b; NIST, 2024; Federal Republic of Nigeria, 2015; Federal Republic of Nigeria, 2024.

6. Task 3 Framework and Control Mapping

Create a mapping matrix demonstrating that the policy manual is connected to recognised security-governance and control frameworks rather than existing as isolated documentation.

1. Select at least 12 significant policy requirements from across the eight policies.
2. Map each requirement to the most relevant ISO/IEC 27001:2022 control theme or control area.
3. Map each requirement to the most relevant NIST Cybersecurity Framework 2.0 function: Govern, Identify, Protect, Detect, Respond or Recover.
4. Where a Nigerian legal or regulatory requirement is materially relevant, identify it accurately and explain the relationship briefly.
5. Use GDPR or other international requirements only where the scenario or data-processing context makes them relevant.

Mapping Table

Below is the mapping matrix for 14 significant policy requirements taken from across the eight policies, mapped with the most relevant ISO/IEC 27001:2022, and to the most relevant NIST Cybersecurity Framework 2.0 function.

S/NO	Policy / Requirement	Business or Risk Objective	ISO/IEC 27001 Alignment	NIST CSF Function	Legal / Regulatory Note
1	Enterprise Policy — CISO-approved policy suite, hierarchy and lifecycle (5.5.3, 5.5.6)	Ensure security direction is authorised, coherent and consistently governed	A.5.1 Policies for information security	Govern (GV.PO) — policy established and communicated	—
2	AUP — Dual-use tools restricted to Authorised Lab Environments (5.5.3)	Prevent offensive-security/forensic tools causing real-world harm	A.8.7 Protection against malware; A.5.15 Access control	Protect (PR.PS) — platform security	Cybercrimes (Prohibition, Prevention, etc.) Act 2015/2024 — unauthorised access/use offences
3	AUP — Prohibition on unauthorised access "testing" (5.5.4)	Prevent students/staff misusing training skills against real systems	A.5.15 Access control	Protect (PR.AA)	Cybercrimes Act 2015/2024
4	Access Control — Mandatory MFA for privileged/forensic-repository access (5.5.3)	Reduce risk of credential compromise on high-value accounts	A.5.17 Authentication information; A.8.5 Secure authentication	Protect (PR.AA) — identity/authentication	—
5	Access Control — Chain-of-custody logging for forensic evidence access (5.5.4)	Preserve evidentiary integrity for legal/disciplinary use	A.5.28 Collection of evidence; A.8.15 Logging	Protect (PR.PS); Detect (DE.CM)	Cybercrimes Act 2015/2024 — evidence admissibility
6	Access Control — Quarterly privileged access review (5.5.8)	Prevent privilege creep and orphaned high-risk access	A.5.18 Access rights; A.8.2 Privileged access rights	Protect (PR.AA)	—
7	Data Classification & Handling — Four-tier classification scheme (5.5.1)	Apply proportionate controls based on sensitivity	A.5.12 Classification of information	Identify (ID.AM) — asset/data management	NDPA 2023 — data minimisation principle
8	Data Classification & Handling — Encryption of Confidential/Restricted data at rest and in transit (5.5.5, 5.5.8)	Protect sensitive data (personal data, evidence, malware) from unauthorised disclosure	A.8.24 Use of cryptography	Protect (PR.DS) — data security	NDPA 2023

9	Data Classification & Handling — Secure disposal of Confidential/Restricted data (5.5.14)	Prevent data recovery after intended destruction	A.8.10 Information deletion; A.7.14 Secure disposal or re-use of equipment	Protect (PR.DS)	NDPA 2023 — storage limitation
10	Incident Response — Mandatory classification and IRT activation for High/Critical incidents (5.5.2, 5.5.5)	Ensure timely, coordinated response proportionate to severity	A.5.24 Incident management planning and preparation; A.5.26 Response to incidents	Respond (RS.MA) — incident management	—
11	Incident Response — DPO assessment of NDPC/data-subject breach notification (5.5.6)	Meet statutory breach-notification timelines	A.5.31 Legal, statutory, regulatory and contractual requirements	Respond (RS.CO) — communications	NDPA 2023 — breach notification obligation
12	Mobile Device & Endpoint — Full-disk encryption and endpoint protection on all devices (5.5.1)	Protect data if a device is lost, stolen or compromised	A.8.1 User endpoint devices; A.8.24 Cryptography	Protect (PR.PS)	—
13	Cloud Security — Only approved cloud services used; provider security/certification vetted before onboarding (5.5.1–5.5.2)	Manage third-party/supply-chain risk for data hosted off-premises	A.5.23 Information security for use of cloud services	Govern (GV.SC) — supply chain risk management	NDPA 2023 — cross-border transfer safeguards
14	Physical Security — Logged, restricted access to forensic labs and the evidence locker (5.5.2, 5.5.4)	Protect physical evidence and high-risk lab infrastructure from unauthorised access	A.7.1 Physical security perimeters; A.7.2 Physical entry	Protect (PR.AA) — physical access control	Cybercrimes Act 2015/2024 — evidence integrity

From the mapping matrix table above, while using the NIST CSF function, it will be noted that several rows touch on two functions, for instance row 5 touches Protect and Detect which has been shown below.

Moreso, ISO/IEC 27001:2022 numbering shows the 2022 restructuring which has 93 controls across four themes, that is Organisational A.5, People A.6, Physical A.7, Technological A.8.

In addition, the Legal/regulatory notes were only added where the requirement has a need for. Row 1,3,6 and 12 do not have which explains why they are left blank. This is because its not every security requirement that carries a distinctive legal citation.

7. Task 4 Implementation, Communication and Exception Management

A policy is only effective when it is communicated, understood, implemented, monitored and reviewed. Develop an implementation plan for the Security Policy Manual.

- Communication plan for staff, students, instructors, administrators and relevant third parties.
- Training and awareness plan appropriate to different user roles.
- Leadership endorsement and visible management sponsorship.
- Implementation sequencing and prioritisation of the policy suite.
- Supporting tools such as templates, standards, forms, checklists or technical controls.
- Formal exception process covering request, risk assessment, approval, compensating controls, expiry and review.
- Feedback and continuous-improvement process.

Implementation Plan for the Security Policy Manual

To ensure the policy is well effected, an implementation plan has been designed for the Security Policy Manual which covers the communication plan.

4.1 Communication Plan

S/NO	Audience	Channel	Key Message	Frequency
1	All staff & instructors	Email + intranet policy portal + mandatory briefing session	What's changing, why, and where to find the full manual	At rollout, then on any material revision
2	Students	LMS announcement + orientation briefing + student handbook update	Acceptable use, lab conduct rules, and consequences of misuse	At enrolment/orientation, then annually as refresher
3	Lab Supervisors/Instructors (as a distinct group)	Dedicated workshop	Their specific accountability for Authorised Lab Environments, evidence handling, and access approvals	Before each academic term
4	IT/Security Operations	Technical implementation briefing + runbooks	Technical control requirements (MFA, encryption, logging, segregation) they must configure and monitor	At rollout, then with each technical standard update

5	Third parties/contractors/vendors	Contract addendum + onboarding briefing	Relevant obligations (e.g., cloud vendor security terms, visitor rules for physical access)	At contract onboarding/renewal
6	Senior Management/Board	Executive summary + quarterly governance report	High-level posture, adoption metrics, major exceptions/incidents	Quarterly

4.2 Training and Awareness Plan

S/NO	Role	Training Content	Format	Cadence
1	New staff/instructors	Full policy suite overview, role-specific obligations, exception process	Onboarding module + live session	Once at onboarding, refreshed annually
2	New students	AUP, lab conduct, data handling basics, incident reporting	Orientation module (LMS-based, short quiz to confirm completion)	Once at enrolment, refreshed annually
3	Lab Supervisors	Chain-of-custody procedures, Authorised Lab Environment approval process, malware/tool escape response	Specialised workshop + tabletop scenario	Per academic term
4	IT/Security Operations	Technical control implementation, incident triage, access review procedures	Technical training + participation in incident tabletop exercises	Annually + post-incident lessons-learned sessions
5	Privileged account holders (admins, forensic repository access)	Heightened responsibility briefing, MFA/credential hygiene	Short mandatory briefing	Annually, tied to access review cycle
6	All Personnel	General Security awareness (phishing, social engineering, reporting culture)	E- learning module	Annually

4.3 Leadership Endorsement and Sponsorship

- The **Board/Senior Management Committee** formally approves the Enterprise Information Security Policy and issues a signed endorsement statement communicated alongside the rollout announcement — this visibly signals that security is an institutional priority, not just an IT initiative.
- The **CISO** acts as the visible executive sponsor, presenting the policy suite rationale at the staff/instructor briefing and student orientation (or delegating this credibly), rather than treating rollout as a pure documentation exercise.
- **Leadership sponsorship is reinforced structurally:** the CISO's quarterly report to the Board (per each policy's Monitoring section) keeps the manual visibly "alive" at governance level rather than something approved once and forgotten.

4.4 Implementation sequencing and prioritisation of the policy suite.

Phase	Policies	Rationale
Phase 1 Foundation	Enterprise Information Security Policy; Access Control Policy	Depends on governance authority and identity/ access being established
Phase 2 Core Operational Risk	Acceptable Use Policy; Data Classification and Handling Policy	Addresses ICDFA's highest-likelihood risk — dual- use tool misuse and mishandling of sensitive/evidence data
Phase 3 Response and Infrastructure	Incident Response Policy; Mobile Device and Endpoint Security Policy; Cloud Security Policy	Builds response capability and secures the technical environments the earlier policies assume exist
Phase 4 Physical	Physical Security Policy	Often has longer lead times (access-card system changes, CCTV, evidence locker procurement), justifying it last

4.5 Supporting Tools

- **Templates:** the Appendix A policy template (already used for all eight documents) reused for any future policy/standard.
- **Standards library:** subordinate standards referenced in the policies (e.g., Password/Authentication Standard, Encryption Standard, Cloud Configuration Baseline) — these operationalise policy detail without needing Board re-approval for minor technical changes.
- **Checklists:** a Lab Supervisor pre-session checklist (Authorised Lab Environment setup, segregation verification); an offboarding checklist (access revocation, device return, evidence handover).
- **Technical controls:** MDM/endpoint management platform, centralised logging/SIEM for access and incident monitoring, an access-review workflow tool, an exceptions register (see 4.6).
- **Central policy portal:** single source of truth for the current approved version of every document, avoiding the classic problem of outdated copies circulating informally.

4.6 Formal Exception Process

The Formal exception process covers request, risk assessment, approval, compensating controls, expiry and review.

- **Request:** Submitted in writing to the Policy Owner via the standard form, stating what is being exempted, why, and for how long.
- **Risk Assessment:** Policy Owner reviews the risk, with GRC/Security input for anything involving Confidential/Restricted data or privileged access.

- Approval: CISO must approve exceptions involving Restricted data, privileged/forensic access, or lab containment; Policy Owner can approve lower-risk, limited exceptions.
- Compensating Controls: Documented with the approval - e.g., extra monitoring, time limits, or restricted access.
- Expiry: Every exception has a fixed expiry date; open-ended exceptions are not allowed.
- Review: All exceptions are logged in a central register and reviewed quarterly by GRC/CISO to spot patterns that may require a control redesign.

4.7 Feedback and Continuous-Improvement Process

- **Channels:** a dedicated feedback mailbox/form for staff, instructors and students to flag unworkable or unclear policy requirements, reviewed by GRC monthly.
- **Post-incident feedback loop:** lessons-learned outputs from the Incident Response Policy's post-incident reviews feed directly into policy revision proposals.
- **Annual policy health check:** GRC compiles exception patterns, audit findings, training completion rates, and feedback-mailbox themes into an annual report to the CISO/Board, which drives the next revision cycle — closing the loop back to the "Review and Revision" stages of the Task 1 lifecycle.
- **Academic calendar alignment:** since ICDFA is an academy, scheduling major policy reviews/training refreshers around term boundaries (rather than an arbitrary calendar date) improves uptake, since it aligns with when students and instructors are already absorbing new-term information anyway.

8. Task 5 Policy Effectiveness and Management Metrics

Define at least eight measurable indicators that ICDFA management can use to determine whether the policy framework is being implemented and whether it is reducing risk.

- Policy acknowledgement / attestation rate.
- Mandatory security-awareness completion rate.
- Access-review completion and exception rate.
- Number, age and recurrence of policy exceptions.
- Incident volume attributable to policy non-compliance.
- Critical policy-control audit findings and remediation status.
- Percentage of policies reviewed within the approved review cycle.
- Endpoint, cloud or data-control compliance metrics relevant to the policy suite.

For each metric, state the metric owner, data source, measurement frequency, target or threshold, reporting audience and management action when the threshold is missed.

Policy Effectiveness and Management Metrics

The below are measurable indicators that the ICDFA management can use to determine whether the policy framework is being implemented and whether it is reducing risk.

No	Metric	Metric Owner	Data Source	Frequency	Target/Threshold	Reporting Audience	Management action
1	Policy acknowledgement / attestation rate	Head of GRC	LMS/HR attestation records	Monthly (rollout period), then quarterly	≥ 95% of active staff, instructors and students	CISO; Board (quarterly summary)	GRC issues targets reminders to non-compliant individuals/departments; persistent non-attestation escalated to line manager/academic lead
2	Mandatory security-awareness training completion rate	Head of GRC	LMS training records	Quarterly	≥ 90% completion within 30 days of assignment	CISO	Automated reminder at 15 days; manager/instructor notified at 30 days; repeat non-completion recorded as a disciplinary/academic matter
3	Access-review completion rate and exception rate	Head of IT Services	IAM system / access review logs	Quarterly (privileged), Annually (standard)	100% of scheduled reviews completed on time; exception rate < 5% of reviewed accounts	CISO	Overdue reviews escalated to System/Data Owner; exception rate above threshold triggers a root-cause review of the underlying access model
4	Number, age and recurrence of policy exceptions	Head of GRC	Central Exceptions Register	Quarterly	No exception open beyond its approved expiry; recurrence of the same exception type < 3 instances/year CISO; Board (significant/high-risk exceptions)	CISO: Board (significant/high-risk exceptions only)	Overdue exceptions auto-escalated to CISO for closure decision; recurring exception type triggers a policy/control redesign review
5	Incident volume attributable to policy non-compliance	Head of Security Operations	Incident Register (root-cause field)	Monthly	Downward or stable trend quarter-on-quarter; no repeat root cause within 2 consecutive quarters	CISO; Board (quarterly)	Repeat root cause triggers mandatory targeted training or control redesign for the affected policy area
6	Critical policy-control audit findings and remediation status	Internal Audit	Internal/external audit reports	Per audit cycle (at least annually)	100% of Critical findings remediated within 90 days	Board; CISO	Overdue Critical findings escalated to Board with a mandatory remediation plan and named accountable owner
7	Percentage of policies reviewed within the approved review cycle	Head of GRC	Policy Register (version/review dates)	Quarterly	100% reviewed within their stated review date (annual, or trigger-based)	CISO; Board	Overdue policy flagged as provisionally "at risk"; Policy Owner required to submit revised timeline to CISO within 2 weeks

8	Endpoint/cloud/data-control compliance rate	Head of IT Services	MDM/endpoint compliance dashboard; cloud service configuration reports	Monthly	≥ 95% of managed endpoints and approved cloud services meeting baseline configuration	CISO	Non-compliant endpoints/services quarantined from Confidential/Restricted data access until remediated
9	Authorised Lab/Research Environment containment integrity (tool/malware "escape" incidents)	Head of Security Operations / Lab Supervisors	Incident Register (escape-classified incidents)	Per incident, reviewed quarterly	Zero uncontained escapes per academic term	CISO; Board	Any escape triggers mandatory post-incident review and suspension of the specific lab exercise/tooling pending remediation
10	Chain-of-custody / forensic evidence access-log integrity	Head of IT Services / DPO	Access logs for evidence repositories and evidence locker	Quarterly	100% of Restricted-data access events individually attributable (no shared-account access)	CISO	Any unattributable access event triggers immediate investigation and review of the relevant access control configuration

REFERENCES

- Center for Internet Security. (2024). *CIS Critical Security Controls (Version 8.1)*. <https://www.cisecurity.org/controls>
- European Parliament and Council of the European Union. (2016). *Regulation (EU) 2016/679 (General Data Protection Regulation)*. Official Journal of the European Union, L119, 1–88.
- Federal Republic of Nigeria. (2015). *Cybercrimes (Prohibition, Prevention, etc.) Act, 2015*.
- Federal Republic of Nigeria. (2023). *Nigeria Data Protection Act, 2023* (Act No. 37). Official Gazette, 119(110).
- Federal Republic of Nigeria. (2024). *Cybercrimes (Prohibition, Prevention, etc.) (Amendment) Act, 2024*.
- GRC102 Week 2 course material: Developing Security Policies and Procedures.
- International Organization for Standardization & International Electrotechnical Commission. (2022a). *ISO/IEC 27001:2022 — Information security, cybersecurity and privacy protection — Information security management systems — Requirements*.
- International Organization for Standardization & International Electrotechnical Commission. (2022b). *ISO/IEC 27002:2022 — Information security, cybersecurity and privacy protection — Information security controls*.
- National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF) 2.0*. U.S. Department of Commerce. <https://www.nist.gov/cyberframework>
- Nigeria Data Protection Commission. (n.d.). *About the NDPC and the Nigeria Data Protection Act 2023*. Retrieved from <https://ndpc.gov.ng>

Appendix A Recommended Policy Template

Document Control Field	Entry
Policy Title	[Policy name]
Policy Owner	[Role / Directorate / Unit]
Approval Authority	[Approving authority]
Version	1.0
Policy Status	Draft
Review Date	

1. Purpose

State why the policy exists and the security or business objective it supports.

2. Scope

Define the people, systems, data, locations, services and third parties covered.

3. Definitions

Define important terms required to interpret the policy consistently.

4. Roles and Responsibilities

Assign policy ownership, implementation, oversight and enforcement responsibilities.

5. Policy Statements

State clear mandatory requirements and prohibited activities.

6. Compliance / Framework Alignment

Identify relevant framework, legal, regulatory or contractual requirements.

7. Exceptions

Define the formal process for requesting, assessing, approving, recording and reviewing exceptions.

8. Enforcement

Define consequences or remediation for non-compliance.

9. Monitoring and Metrics

Define how implementation and effectiveness will be measured.

10. Review and Version Control

Define review frequency, triggers for early review and document-change responsibilities.

11. Related Documents and References

List supporting standards, procedures, guidelines and authoritative references.